B4

PHẦN 1: PHÂN TÍCH HẬU QUẢ & SAI LẦM KỸ THUẬT

1. Bốn Secrets bị phơi bày và hậu quả

- **`OPENAI_API_KEY`:** Hacker chiếm quyền gọi API, làm cạn kiệt hạn mức và trừ sạch tiền thẻ tín dụng (mất 1,200 USD).
- **`STEAM_WEB_API_KEY`:** Thao túng dữ liệu game, gian lận vật phẩm hoặc rút tiền từ ví Steam của studio.
- **`MONGO_URI`:** Lộ tài khoản admin db (`admin_root`). Hacker sẽ xóa sạch, đánh cắp data game hoặc tống tiền.
- **`JWT_SECRET`:** Hacker tự tạo mã Token giả mạo để vượt qua kiểm tra, chiếm quyền Admin điều khiển Backend.

2. Lý do bắt buộc phải thu hồi (Revoke) key lập tức

- **Bot quét trong vài giây:** GitHub Scraper Bot tự động lưu lại các chuỗi Secret chỉ **3 - 5 giây** sau khi commit public.
- **Lịch sử Git lưu vết:** Xóa commit hay chuyển repo sang Private chỉ ẩn code hiện tại. Dữ liệu nhạy cảm **vẫn nằm nguyên trong lịch sử Git (Git History)**, hacker vẫn có thể lục lại được.